

Chapitre 10

Étude de cas — criminalité financière et fraude — corrigés

Corrigé

Jaouad Madkour

Faculté d'Économie et de Gestion de Tanger
Exercices et corrigés · Risque opérationnel et résilience

1 Corrigés des exercices du chapitre

Corrigé de l'exercice 1 — La criminalité financière : un périmètre large, selon la FCA et selon Bâle

- (a) Les quatre composantes de la définition FCA sont : la fraude ou la malhonnêteté, le mésusage d'information sur un marché financier, le traitement du produit d'un crime, et le financement du terrorisme. Le cours traite ensemble fraude et LCB-FT car « deux sujets que la réglementation britannique regroupe sous un même terme, «la criminalité financière», et qui partagent largement les mêmes dispositifs de contrôle » : au-delà du seul regroupement terminologique britannique, la justification de fond tient à la parenté des dispositifs de gestion — sélection et diligence raisonnable à l'entrée, prévention, détection continue, dissuasion — qui s'appliquent indifféremment à un employé indélicat ou à un client blanchisseur, plutôt qu'à une différence de nature entre les deux risques qui justifierait un traitement radicalement séparé. Le chapitre 9 avait approfondi la seule LCB-FT au titre de sa complexité réglementaire propre (GAFI, Bâle); ce chapitre la replace dans son cadre naturel, aux côtés de la fraude, précisément parce que les deux relèvent d'une même famille de risque.
- (b) La précision « sans perte financière nécessaire » est nécessaire car, sans elle, un acte comme le partage de mots de passe ou la mauvaise classification délibérée d'une position de trading — qui viole la réglementation ou la politique interne sans occasionner de perte immédiate et mesurable — resterait hors du périmètre de la fraude interne, alors même qu'il constitue une violation intentionnelle des règles et un facteur de risque à part entière (une position mal classée peut, par exemple, dissimuler un risque qui se matérialisera plus tard). Exemple additionnel d'« activité non autorisée » : un trader qui dépasse délibérément sa limite de position sans en informer sa hiérarchie, sans que cela ne génère de perte sur la période considérée. Exemple additionnel de « vol et fraude » : un employé qui falsifie des notes de frais pour se faire rembourser des dépenses personnelles.
- (c) Les contrôles de fraude externe — sécurité physique des agences et distributeurs, coopération avec les forces de l'ordre — sont structurellement différents des contrôles de fraude interne (séparation des tâches, droits d'accès) car ils portent sur des acteurs et des canaux que la banque ne maîtrise pas de l'intérieur : on ne peut pas « séparer les tâches » d'un braqueur ou d'un fraudeur à la carte bancaire, dont l'accès au système ne procède d'aucune délégation d'autorité interne. Cette différence tient donc à l'identité de l'auteur de la fraude (interne, soumis à l'organisation du travail de la banque; externe, hors de cette organisation) et non à la gravité du préjudice : un vol à main armée externe et un détournement d'actifs interne peuvent être d'égale gravité financière, mais seul le second peut être maîtrisé par des contrôles organisationnels internes.
- (d) Le télétravail massif a démultiplié spécifiquement le hameçonnage par courriel car il a déplacé une part considérable des communications professionnelles hors du périmètre de sécurité contrôlé de l'entreprise (réseau interne, filtrage, vigilance de proximité entre collègues) vers des messageries et des connexions personnelles moins protégées, un canal que les fraudeurs ont immédiatement exploité en multipliant les courriels frauduleux imitant des communications professionnelles désormais plus difficiles à authentifier pour un salarié isolé. Cet épisode illustre que le risque de fraude, bien que « contrôlable » et « produit du comportement humain » au sens des chapitres précédents, dépend aussi de la *surface d'exposition* de l'organisation : un choc exogène (la pandémie) n'a rien changé à la nature du risque de fraude lui-même, mais a brutalement élargi les brèches disponibles pour son exploitation — rappelant que la maîtrise d'un risque contrôlable exige une vigilance renouvelée face à des circonstances changeantes, non un dispositif figé une fois pour toutes.

Corrigé de l'exercice 2 — Gérer le risque de fraude : les quatre piliers et le paradoxe de la tolérance zéro

- (a) La sélection intervient *avant* l'entrée en relation (vérification des antécédents à l'embauche ou lors de la contractualisation avec un tiers); la prévention intervient *pendant* l'exercice courant des fonctions, en structurant continûment l'organisation du travail (séparation des tâches, droits

d'accès) ; la détection intervient *après* qu'un acte potentiellement frauduleux a eu lieu, pour le repérer ; et la dissuasion agit *en amont*, par anticipation de la sanction, tout en ne se concrétisant qu'*après* détection d'un acte avéré. La sélection se distingue de la prévention en ce qu'elle porte sur les *personnes* (employés et tiers) au moment de leur entrée — un filtre one-shot, appliqué une fois — tandis que la prévention porte sur l'*organisation du travail elle-même*, de façon permanente et indépendante de l'identité des personnes en poste : même un employé irréprochable à la sélection reste soumis aux contraintes de séparation des tâches et de droits d'accès limités, car la prévention vise à rendre la fraude structurellement plus difficile à commettre, quelle que soit l'intention de la personne.

- (b) La « tolérance zéro » garantit une sanction systématique *a posteriori* — « tout auteur identifié sera sanctionné » — mais ne garantit nullement l'impossibilité *a priori* de la fraude, le dispositif de prévention ne pouvant, par construction, éliminer tout risque résiduel. La boucle causale à deux étapes est la suivante : la détection, en repérant les cas de fraude, permet d'abord de « limiter l'ampleur du préjudice » pour chaque cas détecté (arrêter la fraude avant qu'elle ne s'aggrave) ; mais elle produit ensuite un effet dissuasif de second ordre sur les fraudes *futures et non encore tentées*, car la probabilité perçue d'être détecté — et donc, via la tolérance zéro, d'être sanctionné avec certitude — devient elle-même « le premier frein à la tentation » pour un fraudeur potentiel qui anticipe rationnellement ce risque. La détection agit ainsi *a posteriori* sur chaque cas individuel, mais *a priori* sur l'incitation collective à frauder.
- (c) Le pilier de dissuasion n'a pas la même portée pratique dans les deux cas : pour un employé, la dissuasion est crédible *ex ante* car il connaît par avance la politique de tolérance zéro de son employeur, en anticipe la sanction certaine en cas de détection, et reste identifiable et sanctionnable au sein d'une relation d'emploi continue. Pour un fraudeur externe anonyme, la dissuasion ne devient opérante qu'*a posteriori*, une fois l'enquête des forces de l'ordre aboutie — si elle aboutit —, sans que le fraudeur, avant l'acte, ne soit nécessairement informé d'une politique spécifique de la banque ni ne partage avec elle de relation préalable rendant la sanction certaine. Ce qui rend la dissuasion interne crédible *ex ante* — la connaissance préalable de la règle par une personne identifiée au sein d'une relation continue — ne s'applique donc pas structurellement à un tiers externe et anonyme.
- (d) Les trois mécanismes de détection — supervision d'équipe, dispositif d'alerte, rapprochements comptables — opèrent tous *après* l'acte potentiellement frauduleux : un rapprochement comptable ne peut que révéler un écart déjà survenu, une alerte ne peut signaler qu'un comportement déjà observé, et une supervision d'équipe ne peut repérer qu'une anomalie déjà commise. Ils sont donc conçus pour intercepter ce qui a *déjà échappé* aux filtres *a priori* de la sélection (mauvais acteur non écarté à l'entrée) et de la prévention (contournement d'une séparation des tâches ou d'un droit d'accès), non pour empêcher l'acte en amont. Un établissement qui n'investirait que dans la sélection et la prévention ne serait pas conforme à la logique des quatre piliers : le cours affirme explicitement que « la détection reste [...] essentielle » précisément parce qu'aucun dispositif de prévention ne rend la fraude impossible — omettre la détection reviendrait à renoncer à tout moyen de limiter l'ampleur du préjudice et à toute source de dissuasion *a posteriori* une fois la prévention contournée.

Corrigé de l'exercice 3 — Lutter contre le blanchiment : trois phases, KYC, RegTech, et le cas USAA

- (a) Le **placement** vise à faire entrer les fonds d'origine illicite dans le système financier légal tout en « dissimulant l'origine des fonds » (entreprise-écran, fausses factures, saupoudrage). L'**empilage** vise à brouiller la traçabilité de ces fonds déjà placés, en multipliant les mouvements (« placements et retraits selon des montants et des schémas variés ») pour rendre leur origine illicite impossible à reconstituer. L'**intégration** vise enfin à réinjecter ces fonds désormais « propres » en apparence dans l'économie légale (faux salaires, faux prêts, dividendes fictifs). L'ordre est nécessairement celui-là car chaque étape présuppose la précédente : on ne peut « brouiller la piste » de fonds (empilage) qui ne sont pas encore entrés dans le système financier (placement), et on ne peut réinjecter dans l'économie légale (intégration) des fonds

dont l'origine n'a pas d'abord été dissimulée et brouillée — une intégration prématurée, avant placement, laisserait la trace directe et non dissimulée entre le fonds et son origine criminelle, ce qui est précisément ce que les trois étapes cherchent collectivement à éviter.

- (b) Les cinq facteurs cités par le cours sont : le pays d'opération, le secteur, l'historique avec la banque, la structure de l'entreprise, et la traçabilité des fonds. L'approche fondée sur le risque, plutôt qu'un socle uniforme, optimise l'arbitrage entre le coût de la diligence raisonnable (temps, personnel, friction pour le client) et l'exhaustivité des contrôles : appliquer le niveau de contrôle le plus strict à *tous* les clients gaspillerait des ressources sur des relations à faible risque tout en risquant de rendre l'accès aux services bancaires prohibitif pour la majorité de la clientèle, tandis qu'un socle trop léger appliqué uniformément laisserait les clients à haut risque sous-contrôlés. La proportionnalité — « plus le risque est élevé, plus les contrôles doivent être stricts » — concentre l'effort de diligence là où le risque résiduel attendu est le plus élevé, maximisant l'efficacité du dispositif pour un coût total donné.
- (c) Un système d'alerte automatisé mal paramétré peut simultanément produire trop de faux positifs *et* laisser passer des faux négatifs car ces deux défauts proviennent de la même cause : un paramétrage qui ne reflète pas correctement le profil de risque réel de la clientèle. Des seuils mal calibrés peuvent, pour certains types de transactions ou de clients, être trop sensibles (déclenchant des alertes sur des comportements en réalité normaux, d'où les faux positifs) tout en étant, pour d'autres types de transactions ou de clients, insuffisamment sensibles (laissant passer des schémas réellement suspects mais non couverts par les règles retenues, d'où les faux négatifs) — les deux erreurs coexistent parce qu'elles résultent d'un même défaut de calibrage plutôt que d'un unique curseur de sensibilité qu'il suffirait de déplacer dans un sens ou dans l'autre. Le suivi des deux types d'erreur constitue une « boucle de rétroaction » car chaque cycle d'alertes traitées (confirmées ou écartées) produit de l'information nouvelle sur la pertinence du paramétrage actuel, information qui doit être réinjectée pour ajuster les règles du système : un réglage figé, non révisé à la lumière de ses propres résultats, ne peut jamais converger vers un équilibre satisfaisant entre les deux types d'erreur, dans un contexte où les typologies de blanchiment évoluent elles-mêmes dans le temps.
- (d) Un système « trop sensible » peut dégrader plutôt qu'améliorer la qualité de la surveillance car il produit, en (c), un excès de faux positifs qui submerge la capacité de traitement des équipes : les 90 000 alertes en arriéré et les 6 900 dossiers non examinés fin 2021 signifient que, faute d'un tri efficace entre vraies et fausses alertes, une part de ces alertes — possiblement de vraies alertes noyées dans la masse — n'a jamais été effectivement analysée à temps, ce qui équivaut, en pratique, à un système qui *rate* des faux négatifs par débordement opérationnel plutôt que par défaut de sensibilité initiale. La sur-sensibilité du système, censée réduire les faux négatifs en théorie, a ainsi paradoxalement pu en créer de nouveaux en pratique, faute du suivi rigoureux et du redimensionnement des équipes que le (c) identifie comme nécessaire. Le cours insiste sur l'absence de faits avérés de blanchiment car cela révèle que l'obligation réglementaire en LCB-FT porte sur des *moyens* (la robustesse démontrable du dispositif de contrôle) et non uniquement sur des *résultats* (un préjudice de blanchiment effectivement caractérisé) : un régulateur peut ainsi sanctionner une défaillance de gouvernance et de contrôle avant même qu'elle n'ait débouché sur un cas avéré, une logique préventive plutôt que strictement réparatrice.

2 Corrigé de l'exercice cumulatif

Corrigé de l'exercice 4 — La criminalité financière à la lumière des quatre chapitres précédents

- (a) Les trois phases du blanchiment, le KYC fondé sur le risque et l'automatisation RegTech de ce chapitre opérationnalisent précisément les exigences générales du chapitre 9 : la compréhension « approfondie des risques ML/FT inhérents à sa base de clientèle » se traduit concrètement par la classification KYC en risque faible/moyen/élevé, et le « système de surveillance adapté à sa taille, ses activités et sa complexité » se traduit par le dispositif RegTech de détection

d'anomalies. Le cas USAA illustre *a contrario* ce qui se produit quand ces exigences ne sont pas satisfaites : un département « significativement sous-effectif », comblé par des « sous-traitants dont les qualifications n'avaient pas été vérifiées ». L'indice le plus direct que la fonction d'audit interne exigée par le chapitre 9 — censée s'assurer que le système de surveillance « est utilisé effectivement » — a elle-même fait défaut chez USAA est que ces défaillances (sous-effectif, sous-traitance non vérifiée, système « trop sensible » générant un arriéré de 90 000 alertes) ont perduré sur plus de cinq ans (janvier 2016 à avril 2021) sans correction interne, jusqu'à être révélées par une sanction *externe* du FinCEN et de l'OCC : si l'audit interne avait effectivement rempli son rôle de « garant de l'effectivité » du dispositif tel que l'exige le chapitre 9, ces manquements structurels auraient dû être détectés et corrigés bien avant que le régulateur n'ait à intervenir lui-même.

- (b) Les défaillances d'USAA s'apparient point par point à celles d'Equifax : le sous-effectif du service conformité d'USAA correspond à l'absence d'« inventaire exhaustif des actifs informatiques » chez Equifax (dans les deux cas, un manque structurel de ressources et de visibilité empêchant une action corrective dans les délais requis) ; le recours à des sous-traitants non qualifiés chez USAA correspond à la « communication interne défaillante » d'Equifax, où l'information pertinente (l'alerte de vulnérabilité, ou ici la compétence requise) n'a pas atteint les bonnes personnes ; et le système « trop sensible », générant un arriéré de 90 000 alertes chez USAA, correspond au certificat SSL expiré d'Equifax — dans les deux cas, un défaut technique retardant considérablement la détection effective d'une activité déjà en cours. Cette correspondance confirme la thèse du chapitre 8 : le cas USAA, comme le cas Equifax, résulte « rarement d'une cause unique », mais d'une conjonction de défaillances qui, prises isolément, auraient chacune pu être maîtrisée. Le même critère interne/externe est pertinent pour la sécurité de l'information et pour la fraude car, dans les deux cas, l'*origine* de la menace (une partie liée à l'organisation par un contrat de travail ou de représentation, ou un tiers totalement extérieur à celle-ci) détermine directement la nature des leviers de contrôle disponibles : des leviers organisationnels internes (séparation des tâches, droits d'accès, politiques de confidentialité) pour la menace interne, des leviers de coopération externe et de sécurité périmétrique (forces de l'ordre, pare-feux, contrats avec des tiers) pour la menace externe — l'objet protégé (argent ou information) important alors moins que la position de la source de la menace par rapport aux frontières de l'organisation.
- (c) L'indicateur prospectif du chapitre 7 (le patch ageing, mesurant un délai déjà écoulé mais révélateur d'une vulnérabilité de gouvernance continue) et le suivi des faux positifs/négatifs de ce chapitre répondent au même problème structurel : un dispositif de détection automatisé — qu'il surveille des vulnérabilités logicielles ou des transactions suspectes — ne reste efficace que si son paramétrage est continuellement réévalué à la lumière de ses propres résultats passés ; à défaut, il se dégrade silencieusement, sans qu'aucun signal n'alerte l'organisation avant qu'un incident majeur ne le révèle. Le système « trop sensible » d'USAA, avec son arriéré de 90 000 alertes non traitées, est un exemple concret et chiffré de ce déficit : c'est précisément l'absence d'un indicateur prospectif de la santé du dispositif de surveillance (par exemple, un ratio d'alertes traitées dans un délai cible, analogue au patch ageing pour la cybersécurité) qui a permis à l'arriéré de croître jusqu'à un niveau matériel avant toute correction, illustrant en LCB-FT le même manque « d'indicateurs prospectifs [...] encore peu harmonisés » que le chapitre 7 identifie pour le risque cyber.
- (d) Les deux cas diffèrent précisément sur le plan factuel : le rapport de l'APRA sur la CBA documentait des manquements *avérés* — « blanchiment de capitaux, surfacturation de clients, pertes de données » —, tandis que la sanction d'USAA ne repose que sur la *qualité défaillante* du dispositif de contrôle, « non sur des faits avérés de blanchiment ». Cette différence révèle que le pouvoir de sanction des régulateurs en matière de risque non financier s'étend au-delà d'une logique strictement réparatrice (sanctionner un préjudice démontré) pour couvrir une logique préventive (sanctionner un risque de préjudice futur, révélé par la seule qualité insuffisante des contrôles) : un régulateur n'a pas besoin d'attendre la matérialisation effective d'un blanchiment pour agir, dès lors que le dispositif censé le prévenir est jugé structurellement défaillant. La formule « meilleur sur le papier qu'en pratique », appliquée par le chapitre 6 à la CBA, décrit également le cas USAA : la banque prétendait maintenir un programme « conforme

aux exigences minimales du Bank Secrecy Act », un objectif affiché « sur le papier », tandis que « en pratique », le sous-effectif chronique, le recours à des sous-traitants non vérifiés et le système de surveillance mal calibré révélaient un dispositif bien en-deçà de cette conformité formelle — exactement l'écart entre le cadre déclaré et le cadre effectivement opérant que le chapitre 6 identifie chez la CBA.

3 Corrigé des applications en sciences économiques

Corrigé de l'exercice 5 — L'arriéré d'alertes LCB-FT : capacité et arbitrage, chiffré

- (a) La capacité de traitement mensuelle actuelle est $55 \times 150 = 8\,250$ alertes par mois. L'accroissement net mensuel de l'arriéré est $12\,000 - 8\,250 = 3\,750$ alertes par mois.
- (b) Après 12 mois, l'arriéré atteint $3\,750 \times 12 = 45\,000$ alertes non traitées. Le nombre de mois nécessaires pour atteindre 90 000 alertes est $90\,000 / 3\,750 = 24$ mois — soit deux ans, un ordre de grandeur cohérent avec la période de janvier 2016 à avril 2021 (plus de cinq ans) sur laquelle le régulateur a documenté les manquements d'USAA, suggérant qu'un tel arriéré, une fois enclenché, peut s'installer durablement en l'absence de correctif.
- (c) Le nombre d'analystes supplémentaires nécessaires pour égaler exactement le flux entrant est $3\,750 / 150 = 25$ analystes (un nombre exact, sans arrondi nécessaire), pour un coût annuel de $25 \times 85\,000 = 2\,125\,000$ \$. Le coût réglementaire attendu est $0,30 \times 140\,000\,000 = 42\,000\,000$ \$, soit $42\,000\,000 / 2\,125\,000 = 19,76$ fois le coût annuel du recrutement. Le recrutement est donc très largement justifié économiquement au regard de ce seul arbitrage : même en ne retenant qu'une fraction modeste de ce ratio de 19,76, l'investissement en personnel reste rentable face au risque de sanction, sans même compter les coûts de remédiation, de réputation et de mobilisation de la direction qu'une sanction de cette ampleur entraînerait par ailleurs.
- (d) À capacité pleine actuelle (8 250 alertes traitées par mois), l'équipe produit $8\,250 \times 3\% = 247,5$ déclarations de soupçon par mois. Une équipe traitant la totalité du flux de 12 000 alertes par mois produirait $12\,000 \times 3\% = 360$ déclarations de soupçon par mois. Le recrutement du (c) permettrait donc $360 - 247,5 = 112,5$ déclarations de soupçon supplémentaires par mois, soit $112,5 \times 12 = 1\,350$ par an. Le coût additionnel par déclaration de soupçon supplémentaire est $2\,125\,000 / 1\,350 = 1\,574,07$ \$. Ce coût par déclaration supplémentaire est un indicateur informatif de l'efficacité marginale du recrutement, mais il ne saurait constituer, à lui seul, un critère de décision suffisant : il ignore la valeur, difficile à quantifier mais potentiellement considérable, du risque réglementaire évité (calculé au (c)) et le fait que résorber l'arriéré protège aussi contre des faux négatifs non détectés dans le stock déjà accumulé. Le calcul du (c), qui met en regard le coût du recrutement et le coût attendu d'une sanction réglementaire majeure, reste le critère décisif pour la décision d'investissement.

Corrigé de l'exercice 6 — Le saupoudrage sous seuil de déclaration, chiffré

- (a) Le nombre de transactions nécessaires est $480\,000 / 9\,600 = 50$ transactions exactement.
- (b) La probabilité qu'aucune des 50 transactions ne soit jamais signalée est $(1 - 0,02)^{50} = 0,98^{50} = 36,4170\%$. La probabilité cumulée qu'au moins une le soit est donc $1 - 36,4170\% = 63,5830\%$. Le rapport entre cette probabilité cumulée et la probabilité $p = 2\%$ d'une transaction isolée est $63,5830 / 2 = 31,79$: le fractionnement en 50 petites transactions multiplie par près de 32 le risque total de détection par rapport au risque encouru par une transaction unique — la conséquence arithmétique directe du fait que chaque transaction supplémentaire ajoute une nouvelle occasion indépendante d'être signalée, un phénomène de composition des probabilités qui va structurellement à l'encontre de l'objectif même du saupoudrage.
- (c) En cas de détection, la perte totale du blanchisseur est la confiscation des 480 000 \$ plus l'amende de 50 000 \$, soit 530 000 \$. En cas de succès, le gain est la commission de 8 %, soit $0,08 \times 480\,000 = 38\,400$ \$. L'espérance de gain de l'opération est $0,364170 \times 38\,400 - 0,635830 \times 530\,000 = 13\,984,12$ —

$336\,990,07 = -323\,005,95 \$$. Cette espérance est nettement **négative** : un blanchisseur qui ne considérerait que ce seul calcul devrait rationnellement renoncer à l'opération, le risque de perte pondéré par sa probabilité dépassant très largement le gain espéré pondéré par la sienne, y compris à un niveau de détection par transaction aussi faible que 2 %.

- (d) À $p = 5\%$, la probabilité qu'aucune transaction ne soit signalée devient $0,95^{50} = 7,6945\%$, et la probabilité cumulée de détection **92,3055 %**. L'espérance de gain à ce niveau est $0,076945 \times 38\,400 - 0,923055 \times 530\,000 = -486\,264,48 \$$, une dégradation supplémentaire d'environ 163 258 \$ par rapport au cas (c). Le seuil de p pour lequel l'espérance de gain de l'opération est exactement nulle vérifie $(1 - p)^{50} = 530\,000 / (38\,400 + 530\,000) = 0,932442$, soit $p = 1 - 0,932442^{1/50} = 0,1398\%$, c'est-à-dire environ 0,14 % — un niveau de détection par transaction extraordinairement faible. Cet ordre de grandeur révèle qu'à l'échelle de 50 transactions, il suffit d'un système RegTech capable de signaler ne serait-ce qu'une transaction structurée sur environ 715 ($1/0,1398\% \approx 715$) pour rendre le saupoudrage déjà irrationnel en espérance : l'efficacité du dispositif décrit par le cours ne tient donc pas à une probabilité de détection élevée par transaction, mais à l'effet de composition inhérent au fractionnement lui-même, qui transforme un risque individuellement faible en un risque cumulé économiquement dissuasif dès que le nombre de transactions requises devient important.

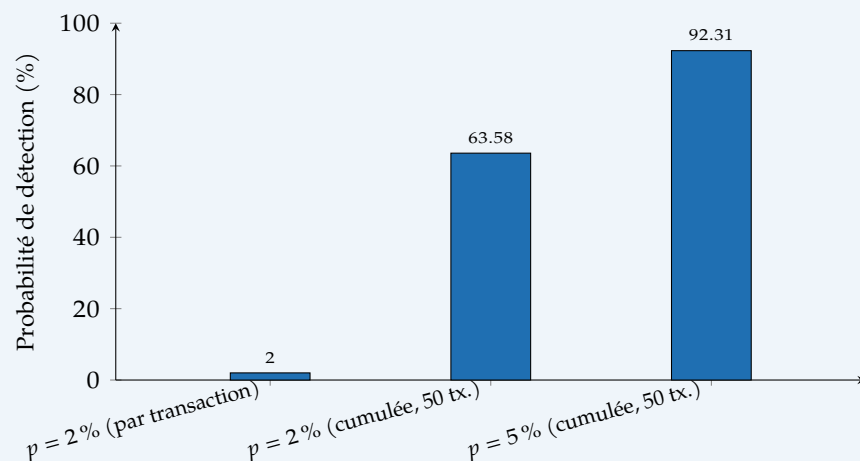


FIG. 1 : Probabilité de détection d'une transaction isolée (2 %) contre probabilité cumulée sur l'ensemble des 50 transactions de saupoudrage, à $p = 2\%$ puis à $p = 5\%$ — exercice 6.